AEGIS BANK

Password Policy

Enterprise AI Decision & Knowledge Platform for Modern Banking

---

Document Information

Field	Details
Document Title	Password Policy
Document ID	**AB-SEC-001**
Department	Information Security
Version	v1.2
Last Updated	July 24, 2026
Document Owner	Information Security Department
Classification	Confidential
Review Date	July 24, 2027
Approved By	**Sami Khan – Chief Executive Officer (CEO)**

Confidentiality Notice

This Password Policy establishes mandatory password standards for employees, contractors, third-party users, and system administrators accessing Aegis Bank systems, applications, networks, and data.

Unauthorized disclosure of this document is prohibited.

Table of Contents

1. Purpose

2. Scope
3. Policy Statement
4. Password Standards
5. Password Complexity Requirements
6. Password Storage Requirements
7. Password Change Requirements
8. Multi-Factor Authentication (MFA)
9. Prohibited Practices
10. Responsibilities
11. Exceptions
12. Frequently Asked Questions
13. Revision History
14. Document Approval

---

1. Purpose

The purpose of this policy is to establish secure password management requirements to protect Aegis Bank information systems, customer data, and confidential business information from unauthorized access.

This policy supports:

- Cybersecurity.
- Data protection.
- Regulatory compliance.
- Fraud prevention.
- Identity protection.
- Operational resilience.

---

2. Scope

This policy applies to:

- Employees
- Contractors
- Consultants
- Third-party service providers
- Temporary staff
- System administrators
- Vendors with authorized system access

It applies to:

- User accounts
- Administrative accounts
- Service accounts
- Databases
- Cloud systems
- Applications
- Network devices
- Mobile devices

---

3. Policy Statement

All passwords must be created, stored, managed, and protected in accordance with this policy.

Passwords shall:

- Be unique.
- Be sufficiently complex.
- Not be shared.
- Be protected from unauthorized disclosure.
- Be used together with MFA where required.

Failure to comply with this policy may result in disciplinary action.

---

4. Password Standards

Passwords must:

- Contain a minimum of **14 characters**.
- Include uppercase letters.
- Include lowercase letters.
- Include numbers.
- Include special characters.
- Avoid predictable patterns.

Examples of strong passwords:

- River!Cloud84$Forest
- Secure#Bank2026!Data

Employees are encouraged to use passphrases instead of short passwords.

---

5. Password Complexity Requirements

Passwords must not include:

- Employee names.
- Usernames.
- Birth dates.
- Simple words.
- Sequential characters.
- Repeated characters.
- Common passwords.

Examples of prohibited passwords:

- password123

- Aegis123
- Welcome1
- 12345678

Systems should enforce password complexity through technical controls where feasible.

---

6. Password Storage Requirements

Passwords must never be:

- Stored in plain text.
- Written on paper in unsecured locations.
- Shared through email or chat.
- Stored in unapproved files.

Approved password managers should be used for secure password storage.

System passwords must be protected using strong cryptographic hashing and salting techniques.

---

7. Password Change Requirements

Standard User Accounts

Passwords should be changed:

- Every **90 days**, or
- Immediately if compromise is suspected.

Privileged Accounts

Administrative account passwords should be reviewed or rotated more frequently according to system risk.

Immediate Password Reset Triggers

Passwords must be reset immediately when:

- A security incident occurs.
- A compromise is suspected.
- An employee changes roles.
- An employee leaves the organization.
- A third-party contract ends.

---

8. Multi-Factor Authentication (MFA)

MFA is mandatory for:

- Remote access.
- Administrative accounts.
- Cloud applications.
- VPN access.
- Sensitive banking systems.
- Email systems.

Approved MFA methods include:

- Authentication applications.
- Hardware security keys.
- One-Time Passwords (OTP).
- Biometric authentication where approved.

SMS-based MFA should only be used where stronger methods are not available.

---

9. Prohibited Practices

The following are prohibited:

- Sharing passwords.
- Reusing passwords across systems.
- Using default passwords.

- Storing passwords in browsers without approval.
- Writing passwords in visible locations.
- Sending passwords through unencrypted channels.

Employees must immediately report suspected password compromise.

---

10. Roles & Responsibilities

Employees

Responsible for:

- Protecting passwords.
- Using approved password practices.
- Reporting incidents.
- Following MFA requirements.

Managers

Responsible for:

- Supporting policy compliance.
- Reporting access changes.
- Ensuring employee awareness.

Information Security Team

Responsible for:

- Monitoring compliance.
- Conducting audits.
- Maintaining technical controls.
- Managing exceptions.

---

11. Policy Exceptions

Exceptions must:

- Be documented.
- Include business justification.
- Receive Information Security approval.
- Be reviewed periodically.

Unauthorized exceptions are prohibited.

---

12. Practical Examples

Example 1 – Strong Password

An employee creates:

Blue!River84Cloud#2026

Result

Complies with password complexity requirements.

Example 2 – Weak Password

Employee uses:

Password123

Result

Rejected by system controls.

Example 3 – Password Sharing

Employee shares login credentials with another employee.

Result

Policy violation requiring investigation.

---

13. Frequently Asked Questions (FAQs)

Q1. How long must passwords be?

At least **14 characters**.

Q2. Can employees reuse passwords?

No. Password reuse across systems is prohibited.

Q3. Is MFA required?

Yes. MFA is mandatory for sensitive systems and remote access.

Q4. Can passwords be shared?

No. Password sharing is strictly prohibited.

Q5. What should I do if I suspect compromise?

Immediately change the password and notify the Information Security Team.

---

14. Related Documents

- MFA Policy (AB-SEC-002)
- Cyber Security Policy (AB-SEC-003)
- Incident Response Plan (AB-SEC-004)
- Data Classification Policy (AB-SEC-005)
- Information Security Standards (AB-SEC-006)
- Acceptable Use Policy (AB-SEC-007)

---

15. Revision History

Version	Date	Description	Author
v1.0	January 10, 2026	Initial Release	Information Security
v1.1	April 15, 2026	Updated Complexity Requirements	Information Security
v1.2	**July 24, 2026**	**Enhanced MFA and Password Protection Controls**	**Information Security**

---

16. Document Approval

Field	Details
Document ID	**AB-SEC-001**
Document Title	**Password Policy**
Department	Information Security
Version	**v1.2**
Classification	**Confidential**
Document Owner	Information Security Department
Approved By	**Sami Khan – Chief Executive Officer (CEO)**
Approval Date	**July 24, 2026**
Next Review Date	**July 24, 2027**

Document Control

Attribute	Value
Document Status	Approved
Distribution	Information Security, IT, All Employees
Language	English

Attribute	Value
Storage Location	Aegis Bank Document Management System (DMS)
Retention Period	7 Years
Supersedes	Password Policy v1.1

End of Document

Aegis Bank
Enterprise AI Decision & Knowledge Platform for Modern Banking

© 2026 Aegis Bank. All Rights Reserved.
